

agenthu 后端基础分支

代码审查报告

面向开发者 A 的 m0/backend-foundation 分支审查
审查提交: e715f9e · 基线: origin/main (6f6a6ec)

项目	结论
审查结论	暂不建议直接合并。当前存在 6 项 P1 阻断问题，主要集中在客户端契约、幂等性、跨用户数据隔离、敏感字段和生产配置安全。
审查范围	Backend API、Event 处理、Focus/Plan/Memory/File 服务、配置、CI 工作流及相关迁移。
验证状态	compileall 通过；pytest 因环境缺少 fastapi 未能启动；git diff --check 发现迁移文件存在尾随空格。

报告用途

本报告用于开发者 A 修复 m0/backend-foundation 分支，并与 React/Tauri 客户端的既定契约对齐。优先级按合并前阻断风险排序，代码位置以审查提交中的文件和行号为准。

一、审查结论

分支已经搭出了认证、事件、任务、计划、Focus、Memory 和文件服务的基础结构，但尚未满足本项目对跨设备同步和校园数据导入的最小可用契约。当前最重要的修复方向是先稳定边界，再扩大功能范围。

项目	结论
合并建议	请求修改后重新审查。P1 问题修复并补充回归测试前，不建议进入主分支。
最高风险	Event 可能重复写入；Focus 完成可能重复累计；Plan/Memory 存在跨用户引用风险；生产环境可使用默认 JWT 密钥。
客户端影响	当前 API 前缀、路由、字段名和状态枚举与 React/Tauri 客户端契约不一致，客户端无法按计划接入。
数据合规影响	后端没有对 Event 任意 JSON 做敏感字段拦截，密码、Cookie、Token 或 OTP 可能进入数据库和日志链路。

优先处理顺序

- 冻结并统一 OpenAPI 路径、请求响应结构和状态枚举，覆盖客户端首期接口。
- 由后端根据 source、upstream_id、semantic_version 计算幂等键，并让 Focus 写入具备幂等语义。
- 补齐 Task、Plan、Event、Memory 的当前用户归属校验，所有查询和引用都限定在认证上下文内。
- 增加敏感字段拒绝或脱敏策略，并在非本地环境拒绝默认 JWT secret。
- 修复 P2 状态校验、上传流式大小限制和 CI 分支触发器，再补充集成测试。

二、P1 阻断问题

P1 Backend API 与 React/Tauri 客户端契约不兼容

影响	客户端按照既定契约调用 /v1 路径和 plans、focus-sessions、events/batch 接口时，会遇到默认 /api/v1 前缀、缺失路由、字段名不一致和状态枚举不一致。M0 无法完成，后续数据同步和 Focus 闭环会被迫返工。
代码证据	backend/config.py:28; backend/api/v1/router.py:20; 客户端 apps/desktop/src/backend/client.ts:30。当前缺少 /events/batch、/plans/today、/focus-sessions 等首期接口。
修复建议	以 TECH_STACK_AND_WORKPLAN.md 中的接口清单为准冻结 OpenAPI；统一前缀、响应包裹结构、时间格式和状态枚举。为每个首期接口添加契约测试，并让客户端只依赖生成或校验后的 contracts。

P1 Event 去重没有按规定的业务键计算

影响	服务只信任可选的客户端 dedupe_key。客户端重试、离线队列重复上传或不同客户端使用不同键时，同一上游事件可能被写入多次，Task/Deadline 投影也会重复。
代码证据	backend/schemas/event.py:20; backend/services/events.py:32。实现没有强制使用 source + upstream_id + semantic_version 生成唯一键。
修复建议	在后端规范化并计算 dedupe key，数据库建立唯一约束；批量接口返回每条事件的 accepted、duplicate 或 rejected 结果。客户端的幂等键只作为辅助信息，不能成为可信边界。

P1 Focus 完成操作不是幂等的

影响	网络重试或用户重复点击完成时，focus.completed 可能被重复写入，实际耗时被重复累加。当前实现也没有持久化 Focus session 或要求先 start，无法可靠表达暂停、恢复和完成状态。
代码证据	backend/services/focus.py:46; backend/services/event_handlers.py:95; backend/api/v1/tasks.py:147。完成事件没有可验证的去重键。
修复建议	为 Focus session 建立持久化记录和状态机；start、pause、resume、complete 均使用 session_id 和版本号；完成请求重复提交时返回同一结果，不重复生成实际耗时。补充并发和重试测试。

P1 Plan 可以引用其他用户的 Task

影响	PlanItemCreate.task_id 未验证 Task 的用户归属。攻击者或错误客户端可以把别人的 Task 写入自己的计划，Focus 投影还可能按 task_id 修改另一个用户的计划数据。
代码证据	backend/api/v1/plans.py:46; backend/schemas/plan.py:13。计划创建路径直接接受 task_id。
修复建议	所有 Task 查询和引用都使用认证上下文过滤；创建计划项时在同一事务中验证 task.user_id；更新和投影时同时校验 plan.user_id 与 task.user_id。对跨用户 ID 添加负向测试。

P1

Backend 未拦截敏感 Event 字段

影响	data、context、provenance 接受任意 JSON，密码、Cookie、Token、OTP 等敏感信息可能被客户端误传并长期存储，随后出现在调试、导出或审计链路中。
代码证据	backend/schemas/event.py:24； backend/services/events.py:37。当前没有递归字段检查、拒绝策略或统一脱敏。
修复建议	在 Event 写入边界增加递归敏感键检测和长度限制，命中 password、cookie、token、authorization、otp、secret 等键时拒绝或脱敏；日志只记录字段路径和事件结果，不记录值。加入敏感日志回归测试。

P1

生产环境可继续使用默认 JWT secret

影响	配置默认值为 dev-insecure-change-me，is_local 没有用于启动保护。若部署时漏配环境变量，攻击者可以伪造令牌或造成全站会话风险。
代码证据	backend/config.py:25、:44。默认密钥和本地标记没有形成非本地环境的硬失败。
修复建议	将 secret_key 改为必填配置；非 local 环境检测到默认值或弱密钥时直接拒绝启动。为配置加载增加测试，并在部署文档中明确密钥轮换方式。

三、P2 重要问题

P2

Replan 缺少计划状态校验

影响	已取消、已完成或已 superseded 的计划仍可能被重新规划，旧计划的语义会被覆盖，客户端无法可靠展示历史和当前计划。
代码证据	backend/services/planner.py:99。重新规划前没有限制 plan.status。
修复建议	明确可重规划状态，例如 draft、active；对 completed、cancelled、superseded 返回业务错误，并通过新计划保存重规划结果，保留原计划审计记录。

P2

Memory 的 source_event_ids 缺少用户归属校验

影响	创建或更新 Memory 时只保存 UUID，不验证 Event 是否属于当前用户。用户可以间接引用其他用户事件，造成隐私泄露和错误 Grounding。
代码证据	backend/api/v1/memory.py:18。source_event_ids 未与认证上下文做关联查询。
修复建议	在写入前批量查询 source_event_ids，并要求全部属于当前用户；缺失或跨用户时整体拒绝。为空数组、部分不存在和跨用户混合输入补充测试。

P2

文件上传先完整读入内存，再检查大小

影响	大文件并发上传会造成不必要的内存压力；对象存储成功而数据库提交失败时还可能产生孤儿对象。
代码证据	backend/api/v1/files.py:39、:50。大小检查发生在完整读取之后。
修复建议	使用分块流式读取并在读取过程中限制大小；数据库和对象存储写入增加补偿删除或后台清理机制，并记录可重试状态。增加超限和提交失败测试。

P2

CI push 触发器只监听 main

影响	feature branch 直接 push 时不会运行 CI，开发者可能在合并前才发现类型、测试或迁移问题。
代码证据	.github/workflows/ci.yml:3-6。push 触发配置仅覆盖 main。
修复建议	让 push 覆盖所有分支或至少覆盖 feature/**，同时保留 pull_request 触发。对依赖服务不可用时明确区分环境失败和代码失败。

四、验证结果

项目	结论
python -m compileall -q backend tests	通过。Python 源文件可以完成语法编译。
python -m pytest	未能启动。当前审查环境缺少 fastapi，报错为 ModuleNotFoundError: No module named 'fastapi'。

项目	结论
git diff --check	发现迁移文件 migrations/versions/339f5d1471c9_initial_schema.py:4 存在 trailing whitespace。
PostgreSQL、Redis、MinIO 集成测试	未运行。审查环境未配置完整服务依赖。

建议的合并前验证

- 安装锁定的 Python 依赖后运行完整 pytest，并补齐认证、Event、Plan、Focus、Memory 的跨用户负向用例。
- 启动 PostgreSQL、Redis、MinIO，运行迁移和 API 集成测试，覆盖批量上传、重复上传、断网恢复和对象存储失败。
- 用 React/Tauri 客户端执行登录、会话恢复、校园事件同步、计划确认、Focus 完成和重复重试流程。
- 检查日志和数据库快照，确认密码、Cookie、Token、OTP 等敏感字段不会被持久化或输出。
- 修复尾随空格并让 CI 在 feature branch push 时执行 lint、typecheck、test 和 cargo test。

五、修复拆分建议

建议将修复拆成三个小批次，便于开发者 A 和 B 并行验证并降低一次性变更的回归范围。

批次	内容	覆盖问题
A1 契约与幂等	统一 /v1 OpenAPI；补齐 events/batch、plans/today、focus-sessions；后端计算 Event 幂等键；Focus session 状态机和重复完成保护。	P1-1、P1-2、P1-3
A2 数据隔离与安全	补齐 Task/Plan/Event/Memory 的 user_id 校验；敏感字段检测和日志脱敏；非本地拒绝默认 JWT secret。	P1-4、P1-5、P1-6、P2-2
A3 可靠性与流水线	限制 Replan 状态；文件流式上传和孤儿对象清理；CI 覆盖 feature branch；补齐集成测试和迁移检查。	P2-1、P2-3、P2-4

重新审查入口

修复后请提供新的 commit 或 pull request，并附上 pytest、集成服务、客户端流程和敏感日志检查的执行结果。重点确认后端 OpenAPI 与 apps/desktop/src/backend/client.ts 及 packages/contracts 的字段完全一致。

附注

本报告只记录审查和验证结果，没有修改 A 分支、创建提交或执行 push。报告中的行号基于审查提交 e715f9e；若分支发生重写，应以新提交重新定位代码证据。